

Remediation Guide

Vulnerability remediation plan

Report Type	Remediation
Tool Source	Qualys
Reporting Month	July 2026

Table of Contents

- 1. Portfolio Risk Overview
- 2. Remediation Actions
- 3. Validation Requirements
- 4. References

1. Portfolio Risk Overview

Tool Source: Qualys

Reporting Month: July 2026

Total Open Findings: 125

2. Remediation Actions

1. Apache Tomcat AJP Request Injection

- Affected Findings: 12 across 4 assets
- Asset Examples: asset-001.corp.local, asset-011.corp.local, asset-021.corp.local, asset-031.corp.local
- CVE: CVE-2020-1938
- Severity: Critical
- Patch Priority: P1
- Advisory: <https://tomcat.apache.org/security-9.html>

Remediation steps:

1. Apply the vendor security update, restart the affected service if required, and validate with a follow-up scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
/opt/tomcat/bin/version.sh
grep -n 'Connector.*AJP' /opt/tomcat/conf/server.xml
# Upgrade Tomcat and disable unused AJP or require a secret
sudo systemctl restart tomcat
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

2. Remote Desktop Weak Encryption Enabled

- Affected Findings: 12 across 4 assets
- Asset Examples: asset-005.corp.local, asset-015.corp.local, asset-025.corp.local, asset-035.corp.local
- CVE: N/A
- Severity: Critical
- Patch Priority: P1
- Advisory: <https://www.qualys.com/research/security-alerts/>

Remediation steps:

1. Apply the vendor security update, restart the affected service if required, and validate with a follow-up scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
Get-HotFix | Sort-Object InstalledOn -Descending | Select-Object -First 10
# Install the approved Microsoft security update and reboot if required
Get-Service TermServLicensing
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

3. Microsoft SQL Server Unsupported Version

- Affected Findings: 12 across 4 assets
- Asset Examples: asset-003.corp.local, asset-013.corp.local, asset-023.corp.local, asset-033.corp.local
- CVE: N/A
- Severity: Critical
- Patch Priority: P1
- Advisory: <https://learn.microsoft.com/sql/sql-server/end-of-support>

Remediation steps:

1. Upgrade the affected software to a vendor-supported release and validate with a follow-up scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
# Replace placeholders with the approved product-specific command
<apply-approved-security-update>
<validate-service-health>
<run-follow-up-scan>
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

4. SMB Signing Not Required

- Affected Findings: 13 across 4 assets
- Asset Examples: asset-007.corp.local, asset-017.corp.local, asset-027.corp.local, asset-037.corp.local
- CVE: N/A

- Severity: Critical
- Patch Priority: P1
- Advisory: <https://learn.microsoft.com/windows/security/threat-protection/security-policy-settings/microsoft-network-server-digittally-sign-communications-always>

Remediation steps:

1. Require SMB signing through Group Policy and validate domain controller and member server policy refresh.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
# Replace placeholders with the approved product-specific command
<apply-approved-security-update>
<validate-service-health>
<run-follow-up-scan>
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

5. Linux Kernel Security Update Available

- Affected Findings: 13 across 4 assets
- Asset Examples: asset-009.corp.local, asset-019.corp.local, asset-029.corp.local, asset-039.corp.local
- CVE: CVE-2024-1086
- Severity: Critical
- Patch Priority: P1
- Advisory: <https://www.qualys.com/research/security-alerts/>

Remediation steps:

1. Apply the vendor security update, restart the affected service if required, and validate with a follow-up scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
uname -r
sudo apt-get update
sudo apt-get install --only-upgrade linux-image-generic
sudo reboot
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.

- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

6. Oracle Java Unsupported Version

- Affected Findings: 13 across 4 assets
- Asset Examples: asset-008.corp.local, asset-018.corp.local, asset-028.corp.local, asset-038.corp.local
- CVE: CVE-2024-20919
- Severity: High
- Patch Priority: P1
- Advisory: <https://www.qualys.com/research/security-alerts/>

Remediation steps:

1. Upgrade the affected software to a vendor-supported release and validate with a follow-up scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
# Replace placeholders with the approved product-specific command
<apply-approved-security-update>
<validate-service-health>
<run-follow-up-scan>
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

7. Apache Log4j Remote Code Execution

- Affected Findings: 12 across 4 assets
- Asset Examples: asset-002.corp.local, asset-012.corp.local, asset-022.corp.local, asset-032.corp.local
- CVE: CVE-2021-44228
- Severity: High
- Patch Priority: P1
- Advisory: <https://logging.apache.org/log4j/2.x/security.html>

Remediation steps:

1. Apply the vendor security update, restart the affected service if required, and validate with a follow-up scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
find /opt -name 'log4j-core-*.jar' -print
# Replace the vulnerable JAR through the approved application release
sudo systemctl restart <affected-service>
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

8. TLS 1.0 Protocol Detection

- Affected Findings: 13 across 4 assets
- Asset Examples: asset-010.corp.local, asset-020.corp.local, asset-030.corp.local, asset-040.corp.local
- CVE: N/A
- Severity: High
- Patch Priority: P1
- Advisory: <https://www.qualys.com/research/security-alerts/>

Remediation steps:

1. Disable TLS 1.0 and TLS 1.1, enable TLS 1.2 or later, then restart the affected service.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
# Replace placeholders with the approved product-specific command
<apply-approved-security-update>
<validate-service-health>
<run-follow-up-scan>
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

9. OpenSSL Security Update Available

- Affected Findings: 12 across 4 assets
- Asset Examples: asset-004.corp.local, asset-014.corp.local, asset-024.corp.local, asset-034.corp.local
- CVE: CVE-2023-0286
- Severity: High
- Patch Priority: P1
- Advisory: <https://www.openssl.org/news/vulnerabilities.html>

Remediation steps:

1. Apply the vendor security update, restart the affected service if required, and validate with a follow-up scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
openssl version -a
sudo apt-get update
sudo apt-get install --only-upgrade openssl
sudo systemctl restart <affected-service>
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

10. Nginx Security Update Available

- Affected Findings: 13 across 4 assets
- Asset Examples: asset-006.corp.local, asset-016.corp.local, asset-026.corp.local, asset-036.corp.local
- CVE: CVE-2025-2345
- Severity: High
- Patch Priority: P1
- Advisory: https://nginx.org/en/security_advisories.html

Remediation steps:

1. Apply the vendor security update, restart the affected service if required, and validate with a follow-up scan.
2. Validate application and service health after the change.
3. Run a follow-up vulnerability scan and retain evidence.

```
# Replace placeholders with the approved product-specific command
<apply-approved-security-update>
<validate-service-health>
<run-follow-up-scan>
```

Rollback and validation:

- Use the approved change rollback procedure if service-health checks fail.
- Confirm the installed version or configuration, validate service health, and verify closure in a follow-up scan.

3. Validation Requirements

Confirm service health, review change evidence, and verify closure in a follow-up vulnerability scan.

4. References

- <https://tomcat.apache.org/security-9.html>
- <https://www.qualys.com/research/security-alerts/>
- <https://learn.microsoft.com/sql/sql-server/end-of-support>
- <https://learn.microsoft.com/windows/security/threat-protection/security-policy-settings/microsoft-network-server-digitally-sign-communications-always>
- <https://logging.apache.org/log4j/2.x/security.html>
- <https://www.openssl.org/news/vulnerabilities.html>
- https://nginx.org/en/security_advisories.html